DocuMind AI

Plataforma Integral de Ingeniería de Software Asistida por Inteligencia Artificial con Auditoría Estática de Ciberseguridad (SAST), Modelado de Amenazas STRIDE y Arquitectura Secure by Design.

Auditoría SAST & SCA Real Inspección estática profunda basada en OWASP Top 10 y ASVS v4.0.3, detección de 10+ tipos de secretos y cálculo de Score 0-100 determinista.	**Suite Documental Completa** Generación automatizada de PRD, SRS, Arquitectura C4 con Trust Boundaries, Diagramas Mermaid en vivo, OpenAPI 3.0, CI/CD, QA y ADRs.	**Hardening de Producción** Seguridad integrada: Helmet CSP estricto, CORS dinámico, doble rate limiter, SafeZip contra Zip Bombs y defensas anti-prompt injection.

1. Canales de Ingesta & Motor de Inspección Local

DocuMind AI procesa proyectos sin ejecutar código de usuario en el servidor anfitrión, garantizando aislamiento total:

Canal de Entrada	Mecanismo Técnico	Garantía de Seguridad
Repositorios GitHub	Clonación e inspección estática del branch principal.	**Solo lectura** (sin permisos de escritura en repo).
Carga de Archivos ZIP	Descompresión en memoria con módulo safeZip.js.	Protección contra **Zip Bombs** y **Path Traversal**.
Prompt / Manual	Ingesta de requerimientos en lenguaje natural.	Defensa contra inyecciones y escape de contexto.

Detección de Stack: Identifica lenguajes (TS, JS, Python, Go, Java, PHP) y frameworks (Express, Nest, FastAPI, React, etc.).

Extracción de DB: Reconstruye esquemas DDL SQL y modelos ORM (Prisma, TypeORM, SQLAlchemy).

Extractor de Endpoints: Mapea rutas HTTP, verbos REST y parámetros sin levantar el servidor.

Hashing SHA-256: Genera digests criptográficos que reducen más del 60% del consumo de tokens.

2. Núcleo DevSecOps 'Secure by Design'

DocuMind AI integra un auditor estático de ciberseguridad que evalúa el código contra estándares internacionales (OWASP Top 10, ASVS v4.0.3 y STRIDE):

100
SCORE BASE

Modelo de Puntuación Determinista (0 a 100) & Deducciones Técnicas
Cálculo matemático sin valoraciones simuladas: Hallazgo Crítico (-25 pts), Alto (-12 pts), Medio (-5 pts) y Bajo (-2 pts). La plataforma califica 8 dimensiones arquitectónicas fundamentales: Autenticación, Autorización, Validación de Entrada, APIs, Secretos, Dependencias, Configuración y Protección de Datos.

Módulos del Motor de Seguridad (services/analyzer/security/)

Componente	Reglas & Patrones Auditados	Mitigación & Salvaguarda
Secret Scanner 10+ Firmas	Claves Gemini (AIza...), OpenAI (sk-...), AWS, GitHub PATs, Stripe, Slack, JWTs, claves privadas RSA/SSH y contraseñas hardcodeadas.	**Enmascaramiento visual seguro** (AIza...****...8F2) y **redacción criptográfica obligatoria** previa al envío al modelo de IA.
Motor SAST OWASP Top 10	Inyección SQL, Cross-Site Scripting (XSS), Inyección de Comandos OS, ejecución peligrosa con eval(), Path Traversal, SSRF, Deserialización Insegura, Hashes MD5/SHA1 y exposición de endpoints.	Diferenciación de certeza técnica: **Detectado/Confirmado** frente a **Uso potencialmente peligroso**, con snippets higienizados.
Dependency Auditor SCA Estático	Inspección no destructiva de package.json, package-lock.json y requirements.txt.	Detección de dependencias vulnerables conocidas y advertencia por uso de versiones flotantes inseguras (*, ^, latest).
STRIDE Modeler Threat Matrix	Modelado de amenazas STRIDE (Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation of Privilege).	Mapeo directo contra componentes del sistema: Frontend UI, API Gateway, Servicios Backend y Base de Datos.
Security Reqs SEC-001..N	Matriz estructurada de requerimientos no funcionales de ciberseguridad.	Clasificados por ID formal, prioridad, estándar ASVS y estado de mitigación listos para el backlog de ingeniería.

Matriz de Amenazas STRIDE Mapeada por Componente

Amenaza STRIDE	Componente Objetivo	Control Arquitectónico Mitigante
Spoofing (Suplantación)	Frontend & API Gateway	Autenticación robusta con tokens JWT firmados criptográficamente y rotación.
Tampering (Alteración)	Tránsito de Datos & APIs	Cifrado forzado TLS 1.3 y firmas de integridad HMAC en payloads críticos.
Repudiation (Repudio)	Controladores Backend	Trazabilidad centralizada de auditoría con correlation IDs e inmutabilidad.
Info Disclosure (Fuga)	Base de Datos & Logs	Almacenamiento cifrado en reposo (AES-256) y redacción automática de logs.
Denial of Service (DoS)	Endpoints HTTP Públicos	Rate limiting multicapa por IP y límites estrictos de tamaño en peticiones.
Elevation of Privilege	Lógica de Negocio & RBAC	Control de acceso basado en roles (RBAC) validado en middleware central.

3. Suite Documental Completa & Frontend Studio

DocuMind AI automatiza la generación integral de la documentación del software a lo largo de todo su ciclo de vida:

Documento / Artefacto	Estándar / Formato	Contenido y Elementos Generados
PRD (Product Requirements)	Markdown Formal	Visión del producto, objetivos de negocio, personas de usuario, casos de uso clave, supuestos y KPIs de éxito medibles.
SRS (Software Requirements)	IEEE-830 Standard	Catálogo formal de Requisitos Funcionales (RF-01...) y Requisitos No Funcionales (RNF: rendimiento, disponibilidad, seguridad).
Arquitectura C4 & Zonas	C4 Model + Mermaid	Diagramas de Contenedores interactivos enriquecidos con **Trust Boundaries** (zonas de confianza), canales TLS y microservicios.
Base de Datos & Diccionario	DDL SQL + Mermaid ERD	Diccionario de datos completo (tablas, columnas, tipos, PK/FK) y diagrama Entidad-Relación (ERD) interactivo renderizado en vivo.
Catálogo de API REST	OpenAPI 3.0.3 (JSON/MD)	Especificación de endpoints, contratos de solicitud/respuesta, códigos HTTP (200, 400, 401, 500) y exportación directa openapi.json.
DevOps & Despliegue	GitHub Actions + Docker	Workflows de CI/CD para testing y despliegue automático, Dockerfile multi-etapa optimizado y docker-compose.yml.
Aseguramiento de Calidad (QA)	Matriz de Testing	Casos de prueba estructurados: pruebas unitarias, de integración, de regresión y pruebas específicas de seguridad.
Decisiones de Arquitectura (ADR)	ADR Log Standard	Registros formales de decisiones de diseño con contexto, alternativas evaluadas, justificación técnica y consecuencias.
Manual de Usuario & README	Guía Operativa	Instrucciones paso a paso para instalación, variables de entorno requeridas, endpoints de verificación y solución de problemas.

Frontend Studio: Experiencia Interactiva en Tiempo Real

Security Center Interactivo
Gauge visual SVG con calificación de grado (A-F), KPIs por severidad, desglose de deducciones y filtros interactivos de hallazgos SAST (All/Crit/High/Med/Low).

Mermaid Studio en Vivo
Renderizado en tiempo real de diagramas de arquitectura C4 y modelos relacionales ERD con controles de zoom, paneo y vista de código fuente.

Comparador de Versiones
Herramienta de análisis diff que compara dos versiones de un proyecto e identifica adiciones, modificaciones y eliminaciones de archivos.

Asistente IA Contextualizado
Chatbot técnico contextualizado con el análisis actual para responder consultas de arquitectura, código y remediación de vulnerabilidades.

4. Hardening de Producción, Exportación & Verificación

DocuMind AI no solo analiza la seguridad de terceros, sino que implementa defensas de nivel bancario en su propia infraestructura:

Vector de Vulnerabilidad	Salvaguarda Implementada en DocuMind AI	Estado de Protección
Cross-Site Scripting (XSS)	Cabeceras **Helmet** con Content Security Policy (CSP) restrictiva. Autorización explícita solo para librerías requeridas (Three.js, Mermaid, Marked).	✔ **Mitigado 100%**
Cross-Origin Resource Sharing	Eliminación de comodín *; lista blanca estricta configurable mediante process.env.CORS_ORIGIN.	✔ **Mitigado 100%**
Ataques de Denegación (DoS)	Doble limitador de tasa: **generalLimiter** (120 req/min) y **analysisLimiter** (20 req/min) en rutas intensivas.	✔ **Mitigado 100%**
Zip Bombs & Path Traversal	Procesamiento en memoria (safeZip.js) con límite de 35 MB, ratio máximo 100:1 y descarte de secuencias ../.	✔ **Mitigado 100%**
Inyección de Prompts en IA	Encapsulación de código en etiquetas <untrusted_source_code> e instrucciones de sistema que prohíben reescribir directivas.	✔ **Mitigado 100%**
Exposición de Secretos	Redacción criptográfica obligatoria previa a la llamada de API de Gemini; ningún secreto en texto claro es procesado por el LLM.	✔ **Mitigado 100%**

Sistema de Exportación Multiformato

1. Paquete ZIP Estructurado
Descarga comprimida con árbol completo de carpetas estándar: PRODUCT/, ARCHITECTURE/, DATABASE/, API/, DEVOPS/, QA/, ADR/, USER_GUIDE/ y SECURITY/.

2. DevSecOps JSON & MD
Endpoints directos /api/project/export/security-json/:id y /security-md/:id para interoperabilidad directa con pipelines de CI/CD, SonarQube o DefectDojo.

3. Modo Impresión PDF
Hoja de estilos dedicada @media print en el frontend que permite exportar la auditoría completa y los diagramas a documento PDF limpio y paginado.

✔ 25 / 25
100% PASS RATE

Certificación de Calidad y Pruebas Automatizadas (Node.js Nativo)
Suite ejecutada íntegramente mediante node tests/test_api.js con **cero fallos**: Sanitizador de variables, clasificador de 16 categorías, hashing SHA-256, extractor de endpoints y tablas SQL, generador documental, exportador ZIP, escáner de secretos, motor SAST, calculador de score, modelador STRIDE, descompresor SafeZip y endpoints de exportación de seguridad.

DocuMind AI Platform — Ingeniería de Software Asistida por Inteligencia Artificial y DevSecOps.
Desarrollado por Daniel Santiago Palencia Sandoval & Nelson Andres Ayala Alvarez • Licencia MIT

LISTO PARA PRODUCCIÓN